

Legal Scope and Isolated Lab - Submission

Student Task: Ethical Hacking Track - Task 02

Objective: Establish safe, legal, and reproducible conditions for security testing.

I. Target Setup - OWASP Juice Shop (Docker)

I'm using OWASP Juice Shop, a deliberately vulnerable web app maintained by OWASP specifically for training. It runs entirely in a local Docker container with no external dependencies.

Setup commands

```
# Pull the official image
docker pull bkimminich/juice-shop

# Run it, bound only to localhost – not
exposed to the LAN or internet
docker run --rm -p 127.0.0.1:3000:3000
bkimminich/juice-shop
```

Verify it's running and reachable only locally:

```
curl -I http://127.0.0.1:3000
docker ps
```

Evidence to capture (screenshots to include in your repo/folder)

- [] Output of `docker ps` showing the container running
- [] Browser screenshot of `http://127.0.0.1:3000` loading the Juice Shop homepage
- [] Output of `docker inspect juice-shop | grep IPAddress` (or `docker network inspect bridge`) showing it's on an internal Docker network, not your host's public interface

Alternative target: DVWA (Damn Vulnerable Web Application) works the same way - `docker run --rm -p 127.0.0.1:8080:80 vulnerables/web-dvwa`.

2. Network Topology - Isolation from Public Networks

The lab is isolated using Docker's default bridge network plus host-only port binding, so the target is never reachable from outside the local machine, let alone the internet.

```

flowchart TB
    subgraph Internet["Public Internet"]
        WAN["❌ No route in or out"]
    end

    subgraph Host["Host Machine (attacker + target)"]
        direction TB
        subgraph DockerNet["Docker Internal Bridge Network (172.17.0.0/16)"]
            Target["🎯 Target Container<br/>OWASP Juice Shop<br/>172.17.0.2:3000"]
        end
        Attacker["💻 Attacker Tools<br/>Browser / Burp Suite / ZAP<br/>127.0.0.1"]
        Firewall["🔒 Host Firewall<br/>Port 3000 bound to 127.0.0.1 only"]
    end

    Attacker -->|"http://127.0.0.1:3000"| Firewall
    Firewall -->|"loopback only"| Target
    Internet -.->|"blocked – no port forwarding,<br/>no public bind address"| Firewall

    style Internet fill:#3a1a1a,stroke:#c0392b,color:#fff
    style WAN fill:#3a1a1a,stroke:#c0392b,color:#fff
    style DockerNet fill:#3a1a1a,stroke:#c0392b,color:#fff

```

```

fill:#1a2e1a,stroke:#27ae60,color:#fff
style Target
fill:#1a2e1a,stroke:#27ae60,color:#fff
style Attacker
fill:#1a1a3a,stroke:#2980b9,color:#fff
style Firewall
fill:#2e2e1a,stroke:#f39c12,color:#fff

```

Isolation controls in place:

Control	How it's enforced
No public exposure	Container port is bound to 127.0.0.1 only (-p 127.0.0.1:3000:3000), not 0.0.0.0
No port forwarding	Home/office router is not configured to forward any port to this host
Network segmentation	Target runs on Docker's isolated bridge network, separate from the host's LAN-facing interface
No credentials reused	Juice Shop uses its own seeded accounts; no real personal or work credentials are ever entered
Ephemeral state	--rm flag destroys the container (and any changes) when stopped, giving a clean baseline every run

3. Rules of Engagement (Personal Lab)

Tester: [Your Name]

Date: [Date you run the lab]

Environment: Personal, self-hosted, local-only lab

3.1 Authorized Target

- Only the Docker container(s) I personally deployed on my own machine, specifically `bkimminich/juice-shop` (and optionally `vulnerables/web-dvwa`), reachable solely at `127.0.0.1`.
- No other host, device, IP range, or domain - including my own router, ISP, or any third-party service - is in scope.

3.2 Allowed Techniques

- Manual browsing and manipulation of the Juice Shop / DVWA application (e.g., parameter tampering, testing input fields).
- Use of a local intercepting proxy (Burp Suite Community / OWASP ZAP) configured to only proxy traffic to `127.0.0.1`.
- Automated scanning tools (e.g., `nikto`, `sqlmap`, ZAP active scan) only when explicitly pointed at `127.0.0.1`.
- Reviewing source code of the vulnerable application if provided.

3.3 Exclusions (Explicitly Prohibited)

- Any system I do not own or have not personally deployed - this includes my home router/modem, ISP infrastructure, neighbors' networks, employer networks, or any public website.
- Any scanning, probing, or connection attempt to a non-loopback / non-container IP address.
- Denial-of-service or resource-exhaustion techniques against anything other than my own disposable container.
- Social engineering, phishing, or testing against real people or real accounts.
- Uploading, exfiltrating, or publishing any data outside this isolated lab.

3.4 Stop Conditions

Testing stops immediately if:

- The target application becomes unexpectedly reachable from outside `127.0.0.1` (e.g., I notice it bound to `0.0.0.0`).
- I observe any traffic leaving the lab network toward a non-loopback destination that I did not explicitly initiate.
- Any real/personal credentials are accidentally entered into the target application.
- The container needs to be shared with or exposed to another person - at that point, written scope agreement from that person would be required before continuing.

3.5 Legal Acknowledgement

I confirm that:

- I own and control every system in scope (my own hardware running local, disposable Docker containers).
- I am not testing any system belonging to another person, company, or organization without explicit written authorization.
- I understand that unauthorized access to computer systems is illegal under laws such as the Computer Fraud and Abuse Act (US), the Computer Misuse Act (UK), and equivalent legislation elsewhere, and that this lab is designed specifically to avoid any such exposure.

Signed: [Your typed name]

Date: [Date]

4. Optional Portfolio Upgrade - Baseline Snapshot

To capture a clean, repeatable baseline for future testing sessions:

```
# Commit the running container's exact
state to a reusable image
docker commit <container_id> juice-shop-
baseline:v1

# Save it as a portable archive
```

```
docker save juice-shop-baseline:v1 -o
juice-shop-baseline-v1.tar
```

Store `juice-shop-baseline-v1.tar` alongside this document. Any time you want to reset to a known-good starting point, load it with `docker load -i juice-shop-baseline-v1.tar` and run a fresh container from that image - this guarantees every future test run starts from identical conditions.

Folder contents for submission

```
/lab-submission
├── README.md                (this
file - topology + ROE + setup)
├── evidence/
│   ├── docker-ps-output.png
│   ├── juice-shop-homepage.png
│   └── network-inspect-output.png
└── juice-shop-baseline-v1.tar
(optional, portfolio upgrade)
```